

CYROPAY LTD

Vendor Risk Assessment — Scored Assessments

Document Classification: Internal
Document ID: VRA-SCR-001
Version: 1.0
Document Owner: Chief Information Security Officer (CISO)
Effective Date: May 2026
Review Date: May 2027
Status: Approved

1. Overview

This document presents the scored security assessments for CyroPay Ltd's three critical third-party vendors: Amazon Web Services (AWS), Stripe, and Salesforce. Assessments are based on the CyroPay Vendor Risk Questionnaire (VRA-Q001), publicly available assurance documentation, and contractual review. Each vendor has been scored against 25 questions across 10 security domains, with a maximum possible score of 50.

2. Summary Scorecard

Vendor	Service	Score /50	Score %	Risk Rating	Assessment Date
Amazon Web Services	Cloud Infrastructure	47/50	94.0%	Low	May 2026
Stripe	Payment Processing	45/50	90.0%	Low	May 2026
Salesforce	CRM	36/50	72.0%	Medium	May 2026

3. Amazon Web Services (AWS)

Document Reference: VRA-001 | Service: Cloud Infrastructure — Compute, Storage, Networking, Security Services (IaaS/PaaS)

Certifications on File: ISO/IEC 27001:2022, SOC 1/2/3 Type II, PCI DSS Level 1, CSA STAR Level 2, FedRAMP High

Overall Score: 47/50 (94.0%) | Risk Rating: Low

Question-Level Scores

Information Security Governance

Q#	Question (summary)	Response	Score
Q01	Does the vendor maintain a formal Information Security Management System (ISMS) ...	Yes / Fully Met	2
Q02	Does the vendor have a documented and board-approved information security policy...	Yes / Fully Met	2
Q03	Does the vendor have a named executive accountable for information security (e.g...	Yes / Fully Met	2

Access Control

Q#	Question (summary)	Response	Score
----	--------------------	----------	-------

Q04	Does the vendor enforce Multi-Factor Authentication (MFA) for all remote access,...	Yes / Fully Met	2
Q05	Does the vendor apply least-privilege principles and conduct formal access review...	Yes / Fully Met	2
Q06	Does the vendor operate a Privileged Access Management (PAM) solution with session...	Yes / Fully Met	2

Data Protection

Q#	Question (summary)	Response	Score
Q07	Is all data at rest and in transit encrypted using industry-standard cryptograph...	Yes / Fully Met	2
Q08	Does the vendor maintain a formal data classification scheme and apply handling ...	Yes / Fully Met	2
Q09	Does the vendor have documented data retention and secure deletion procedures fo...	Yes / Fully Met	2

Vulnerability Management

Q#	Question (summary)	Response	Score
Q10	Does the vendor operate a formal vulnerability scanning programme with defined S...	Yes / Fully Met	2
Q11	Does the vendor conduct annual external penetration testing by an accredited thi...	Yes / Fully Met	2
Q12	Does the vendor maintain a secure software development lifecycle (SDLC) with man...	Yes / Fully Met	2

Incident Response

Q#	Question (summary)	Response	Score
Q13	Does the vendor maintain a documented Incident Response Plan tested at least ann...	Yes / Fully Met	2
Q14	Will the vendor notify CyroPay of a security incident affecting CyroPay data wit...	Partial / Evidence Requested	1

Q15	Does the vendor maintain an incident register and conduct post-incident reviews ...	Yes / Fully Met	2
-----	---	-----------------	---

Business Continuity & Resilience

Q#	Question (summary)	Response	Score
Q16	Does the vendor have documented Business Continuity and Disaster Recovery Plans ...	Yes / Fully Met	2
Q17	Are defined Recovery Time Objectives (RTO) and Recovery Point Objectives (RPO) p...	Yes / Fully Met	2
Q18	Does the vendor operate geographically redundant infrastructure to ensure contin...	Yes / Fully Met	2

Supply Chain & Sub-processors

Q#	Question (summary)	Response	Score
Q19	Does the vendor maintain a register of material sub-processors and fourth partie...	Yes / Fully Met	2

Q20	Does the vendor notify CyroPay of any material changes to its sub-processor arra...	Partial / Evidence Requested	1
-----	---	------------------------------	---

Audit & Compliance

Q#	Question (summary)	Response	Score
Q21	Does the vendor hold current third-party assurance certifications relevant to th...	Yes / Fully Met	2
Q22	Does the vendor contractually permit CyroPay (or its appointed auditor) to condu...	Partial / Evidence Requested	1
Q23	Does the vendor have a formal compliance monitoring programme covering applicabl...	Yes / Fully Met	2

Physical & Environmental Security

Q#	Question (summary)	Response	Score
Q24	Are vendor data centres and facilities protected by physical security controls i...	Yes / Fully Met	2

Exit & Data Return

Q#	Question (summary)	Response	Score
Q25	Does the vendor have a documented exit plan that guarantees return or secure del...	Yes / Fully Met	2

Domain Scores

Domain	Score	Coverage %
Information Security Governance	6/6	100%
Access Control	6/6	100%
Data Protection	6/6	100%
Vulnerability Management	6/6	100%
Incident Response	5/6	83%
Business Continuity & Resilience	6/6	100%
Supply Chain & Sub-processors	3/4	75%
Audit & Compliance	5/6	83%
Physical & Environmental Security	2/2	100%
Exit & Data Return	2/2	100%

Identified Gaps and Recommendations

Q#	Domain	Finding and Recommendation
Q14	Incident Response	Notification SLA to CyroPay for security events contractually defined as 72 hours via AWS Health Dashboard; CyroPay requires direct notification within 24 hours for incidents affecting CyroPay data — contractual amendment recommended.
Q20	Supply Chain	AWS sub-processor change notifications are published via the AWS website but CyroPay is not proactively notified. CyroPay should subscribe to AWS service notifications and review sub-processor list quarterly.
Q22	Audit & Compliance	AWS does not permit customer-directed penetration testing of shared infrastructure. CyroPay may test within its own AWS account perimeter only. AWS provides third-party audit reports (SOC 2) as compensating assurance.

Assessment Summary

AWS represents a Low risk vendor for CyroPay. AWS maintains an exceptionally mature security posture supported by a comprehensive portfolio of third-party certifications. The shared responsibility model is well documented and CyroPay's

obligations within its AWS tenancy are clearly defined. Identified gaps relate primarily to notification timeliness and the structural limitations of auditing a hyperscale cloud provider rather than deficiencies in AWS's own controls.

3. Stripe Inc.

Document Reference: VRA-002 | Service: Payment Processing — Hosted Payment Page / Hosted Fields implementation; PCI DSS-compliant card data processing

Certifications on File: PCI DSS Level 1 Service Provider, ISO/IEC 27001:2022, SOC 1/2 Type II, PCI 3DS

Overall Score: 45/50 (90.0%) | Risk Rating: Low

Question-Level Scores

Information Security Governance

Q#	Question (summary)	Response	Score
Q01	Does the vendor maintain a formal Information Security Management System (ISMS) ...	Yes / Fully Met	2
Q02	Does the vendor have a documented and board-approved information security policy...	Yes / Fully Met	2
Q03	Does the vendor have a named executive accountable for information security (e.g...	Yes / Fully Met	2

Access Control

Q#	Question (summary)	Response	Score
Q04	Does the vendor enforce Multi-Factor Authentication (MFA) for all remote access,...	Yes / Fully Met	2
Q05	Does the vendor apply least-privilege principles and conduct formal access review...	Yes / Fully Met	2
Q06	Does the vendor operate a Privileged Access Management (PAM) solution with session...	Partial / Evidence Requested	1

Data Protection

Q#	Question (summary)	Response	Score
Q07	Is all data at rest and in transit encrypted using industry-standard cryptography...	Yes / Fully Met	2
Q08	Does the vendor maintain a formal data classification scheme and apply handling ...	Yes / Fully Met	2
Q09	Does the vendor have documented	Yes / Fully Met	2

	data retention and secure deletion procedures fo...		
--	---	--	--

Vulnerability Management

Q#	Question (summary)	Response	Score
Q10	Does the vendor operate a formal vulnerability scanning programme with defined S...	Yes / Fully Met	2
Q11	Does the vendor conduct annual external penetration testing by an accredited thi...	Yes / Fully Met	2
Q12	Does the vendor maintain a secure software development lifecycle (SDLC) with man...	Yes / Fully Met	2

Incident Response

Q#	Question (summary)	Response	Score
Q13	Does the vendor maintain a documented Incident Response Plan tested at least ann...	Yes / Fully Met	2
Q14	Will the vendor	Yes / Fully Met	2

	notify CyroPay of a security incident affecting CyroPay data wit...		
Q15	Does the vendor maintain an incident register and conduct post-incident reviews ...	Partial / Evidence Requested	1

Business Continuity & Resilience

Q#	Question (summary)	Response	Score
Q16	Does the vendor have documented Business Continuity and Disaster Recovery Plans ...	Yes / Fully Met	2
Q17	Are defined Recovery Time Objectives (RTO) and Recovery Point Objectives (RPO) p...	Yes / Fully Met	2
Q18	Does the vendor operate geographically redundant infrastructure to ensure contin...	Yes / Fully Met	2

Supply Chain & Sub-processors

Q#	Question (summary)	Response	Score
Q19	Does the vendor	Partial / Evidence	1

	maintain a register of material sub-processors and fourth partie...	Requested	
Q20	Does the vendor notify CyroPay of any material changes to its sub-processor arra...	Partial / Evidence Requested	1

Audit & Compliance

Q#	Question (summary)	Response	Score
Q21	Does the vendor hold current third-party assurance certifications relevant to th...	Yes / Fully Met	2
Q22	Does the vendor contractually permit CyroPay (or its appointed auditor) to condu...	Partial / Evidence Requested	1
Q23	Does the vendor have a formal compliance monitoring programme covering applicabl...	Yes / Fully Met	2

Physical & Environmental Security

Q#	Question (summary)	Response	Score
Q24	Are vendor data centres and	Yes / Fully Met	2

	facilities protected by physical security controls i...		
--	---	--	--

Exit & Data Return

Q#	Question (summary)	Response	Score
Q25	Does the vendor have a documented exit plan that guarantees return or secure del...	Yes / Fully Met	2

Domain Scores

Domain	Score	Coverage %
Information Security Governance	6/6	100%
Access Control	5/6	83%
Data Protection	6/6	100%
Vulnerability Management	6/6	100%
Incident Response	5/6	83%
Business Continuity & Resilience	6/6	100%
Supply Chain & Sub-processors	2/4	50%
Audit & Compliance	5/6	83%
Physical & Environmental	2/2	100%

Security		
Exit & Data Return	2/2	100%

Identified Gaps and Recommendations

Q#	Domain	Finding and Recommendation
Q06	Access Control	Stripe's PAM implementation details are not publicly disclosed. Evidence of session recording for privileged accounts was not available. Stripe's SOC 2 report provides partial assurance; direct evidence requested.
Q15	Incident Response	Post-incident review outputs are not shared with customers. CyroPay should request a summary post-incident report for any incident affecting CyroPay transaction data as part of contractual negotiations.
Q19	Supply Chain	Stripe's sub-processor list is published but not proactively notified. CyroPay should implement a process to review Stripe's sub-processor page quarterly.
Q20	Supply Chain	Advance notification of sub-processor changes not contractually guaranteed under standard Stripe terms.

		CyroPay should negotiate enhanced notification terms.
Q22	Audit & Compliance	Customer-directed audit rights limited under standard Stripe terms. SOC 2 Type II report available upon NDA signature. CyroPay should obtain and review annually.

Assessment Summary

Stripe represents a Low-Medium risk vendor for CyroPay. As a PCI DSS Level 1 Service Provider, Stripe's security controls for cardholder data are among the most rigorously assessed in the payments industry. The hosted payment page implementation means CyroPay's ISMS boundary does not include cardholder data, materially reducing the risk exposure. Gaps identified relate to transparency of internal controls and sub-processor notification practices rather than fundamental security deficiencies.

3. Salesforce Inc.

Document Reference: VRA-003 | Service: Customer Relationship Management (CRM) — merchant and partner relationship data, sales pipeline, support workflows

Certifications on File: ISO/IEC 27001:2022, SOC 1/2 Type II, PCI DSS (where applicable), ISO 27017, ISO 27018

Overall Score: 36/50 (72.0%) | Risk Rating: Medium

Question-Level Scores

Information Security Governance

Q#	Question (summary)	Response	Score
----	--------------------	----------	-------

Q01	Does the vendor maintain a formal Information Security Management System (ISMS) ...	Yes / Fully Met	2
Q02	Does the vendor have a documented and board-approved information security policy...	Yes / Fully Met	2
Q03	Does the vendor have a named executive accountable for information security (e.g...	Yes / Fully Met	2

Access Control

Q#	Question (summary)	Response	Score
Q04	Does the vendor enforce Multi-Factor Authentication (MFA) for all remote access,...	Yes / Fully Met	2
Q05	Does the vendor apply least-privilege principles and conduct formal access review...	Partial / Evidence Requested	1
Q06	Does the vendor operate a Privileged Access Management (PAM) solution with	Partial / Evidence Requested	1

	sessi...		
--	----------	--	--

Data Protection

Q#	Question (summary)	Response	Score
Q07	Is all data at rest and in transit encrypted using industry-standard cryptograph...	Yes / Fully Met	2
Q08	Does the vendor maintain a formal data classification scheme and apply handling ...	Partial / Evidence Requested	1
Q09	Does the vendor have documented data retention and secure deletion procedures fo...	Partial / Evidence Requested	1

Vulnerability Management

Q#	Question (summary)	Response	Score
Q10	Does the vendor operate a formal vulnerability scanning programme with defined S...	Yes / Fully Met	2
Q11	Does the vendor conduct annual external penetration testing by an accredited thi...	Yes / Fully Met	2

Q12	Does the vendor maintain a secure software development lifecycle (SDLC) with man...	Partial / Evidence Requested	1
-----	---	------------------------------	---

Incident Response

Q#	Question (summary)	Response	Score
Q13	Does the vendor maintain a documented Incident Response Plan tested at least ann...	Yes / Fully Met	2
Q14	Will the vendor notify CyroPay of a security incident affecting CyroPay data wit...	Partial / Evidence Requested	1
Q15	Does the vendor maintain an incident register and conduct post-incident reviews ...	Partial / Evidence Requested	1

Business Continuity & Resilience

Q#	Question (summary)	Response	Score
Q16	Does the vendor have documented Business Continuity and Disaster Recovery Plans ...	Yes / Fully Met	2

Q17	Are defined Recovery Time Objectives (RTO) and Recovery Point Objectives (RPO) p...	Partial / Evidence Requested	1
Q18	Does the vendor operate geographically redundant infrastructure to ensure contin...	Yes / Fully Met	2

Supply Chain & Sub-processors

Q#	Question (summary)	Response	Score
Q19	Does the vendor maintain a register of material sub-processors and fourth partie...	Partial / Evidence Requested	1
Q20	Does the vendor notify CyroPay of any material changes to its sub-processor arra...	No / Not Met	0

Audit & Compliance

Q#	Question (summary)	Response	Score
Q21	Does the vendor hold current third-party assurance certifications relevant to th...	Yes / Fully Met	2
Q22	Does the vendor	Partial / Evidence	1

	contractually permit CyroPay (or its appointed auditor) to condu...	Requested	
Q23	Does the vendor have a formal compliance monitoring programme covering applicabl...	Partial / Evidence Requested	1

Physical & Environmental Security

Q#	Question (summary)	Response	Score
Q24	Are vendor data centres and facilities protected by physical security controls i...	Yes / Fully Met	2

Exit & Data Return

Q#	Question (summary)	Response	Score
Q25	Does the vendor have a documented exit plan that guarantees return or secure del...	Partial / Evidence Requested	1

Domain Scores

Domain	Score	Coverage %
Information Security	6/6	100%

Governance		
Access Control	4/6	67%
Data Protection	4/6	67%
Vulnerability Management	5/6	83%
Incident Response	4/6	67%
Business Continuity & Resilience	5/6	83%
Supply Chain & Sub-processors	1/4	25%
Audit & Compliance	4/6	67%
Physical & Environmental Security	2/2	100%
Exit & Data Return	1/2	50%

Identified Gaps and Recommendations

Q#	Domain	Finding and Recommendation
Q05	Access Control	Salesforce access review responsibility is shared with CyroPay as tenant administrator. CyroPay has not implemented a formal quarterly access review process for Salesforce users — this is a CyroPay remediation item.
Q06	Access Control	Salesforce PAM is the

		responsibility of CyroPay's Salesforce administrators. No dedicated PAM tool is in use for Salesforce privileged access. Remediation: implement admin session controls and review.
Q08	Data Protection	Data classification labels are not consistently applied within Salesforce. CyroPay should configure Salesforce data classification fields and enforce handling rules aligned to POL-006.
Q09	Data Protection	CyroPay has not formally documented data retention schedules within Salesforce. Archive and deletion rules should be configured to align with CyroPay's retention policy.
Q12	Vulnerability Management	Salesforce's SDLC assurance is evidenced through SOC 2; however, details of application security testing are not provided at a level sufficient for CyroPay's assurance requirements. Annual review of Salesforce security release notes recommended.
Q14	Incident Response	Salesforce notification SLA is 72 hours for confirmed incidents under standard terms. CyroPay requires 24-hour notification.

		Contractual amendment or enhanced support tier required.
Q15	Incident Response	Post-incident review outputs not shared with customers under standard terms. CyroPay should request incident notification and summary as part of contract review.
Q17	Business Continuity	Salesforce SLA commitments are published (99.99% uptime) but formal RPO/RTO documentation specific to CyroPay's configuration is not provided. CyroPay should document its own RTO/RPO expectations and confirm Salesforce can meet them.
Q19	Supply Chain	Salesforce sub-processor list published but not proactively communicated. CyroPay should review annually and confirm GDPR sub-processor obligations are met.
Q20	Supply Chain	No advance notification of sub-processor changes under standard Salesforce terms. CyroPay should negotiate notification provisions.
Q22	Audit & Compliance	Customer audit rights limited under standard Salesforce terms. SOC 2 Type II available. CyroPay should request and review

		the current report.
Q23	Audit & Compliance	CyroPay does not currently conduct formal compliance monitoring of its Salesforce configuration. A quarterly Salesforce security configuration review should be established.
Q25	Exit & Data Return	Salesforce data export is the customer's responsibility. CyroPay does not have a documented Salesforce exit plan. This should be developed as part of the supplier management programme.

Assessment Summary

Salesforce represents a Medium risk vendor for CyroPay. Salesforce maintains strong platform-level security controls supported by ISO 27001 and SOC 2 certifications. However, a significant number of gaps identified reflect CyroPay's own configuration and governance responsibilities as a Salesforce tenant rather than deficiencies in Salesforce's platform controls. CyroPay must treat these as internal remediation items. The Salesforce instance holds merchant and partner data classified as Confidential under POL-006, and appropriate tenant-side controls must be prioritised.

4. Document Control

Version	Date	Author	Changes
1.0	May 2026	CyroPay GRC Team	Initial version